

**Laporan Keamanan Informasi
Threat Modeling dan Analisis Risiko**

**Pangeran Sunday Marcellino P.S.H - G6401231035
Felicia - G6401241060
Benadeo Eldian Manting - G6401231117**



1. Tujuan Dokumen

Dokumen bertujuan untuk menjabarkan Kerentanan dan Ancaman awal pada IPB Academic Service helper, yaitu sistem yang diasumsikan belum memiliki sistem keamanan yang matang seperti enkripsi, kontrol akses berbasis peran (RBAC), audit logging, maupun tanda tangan digital. Karena beroperasi tanpa proteksi awal, platform terintegrasi ini rentan terhadap eksploitasi data sensitif seperti kredensial akun, data pribadi mahasiswa (NIM/email), dokumen aduan, dan riwayat transaksi internal. Analisis ini penting untuk mengidentifikasi secara dini titik lemah (vulnerabilities) serta potensi skenario serangan, seperti kebocoran kredensial akibat Rainbow Table, manipulasi tiket akademik, pelanggaran wewenang, hingga tindakan penyangkalan (repudiation).

Hasil threat modeling digunakan untuk menurunkan kebutuhan keamanan yang akan diimplementasikan pada tahap berikutnya. Hasil identifikasi risiko ini menjadi fondasi utama dalam merumuskan matriks kebutuhan keamanan berlapis yang mencakup aspek confidentiality, integrity, autentikasi, otorisasi, dan akuntabilitas (AAA), guna mewujudkan arsitektur sistem yang aman dan tangguh pada tahap pengembangan selanjutnya.

1.1 Ruang Lingkup

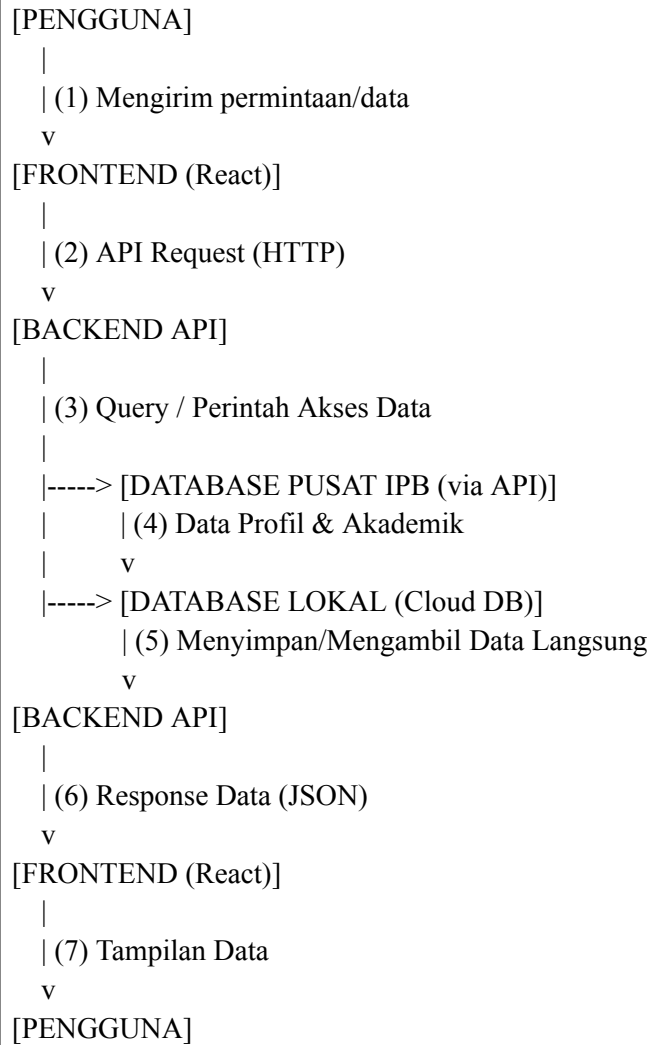
Threat modeling mencakup:

- Manajemen autentikasi dan sesi pengguna.
- Pengelolaan data profil dan akademik mahasiswa.
- Pengajuan dan penanganan tiket bantuan.
- Penerbitan surat rekomendasi dan legalisir.
- Pemrosesan transaksi pembayaran layanan.
- Sinkronisasi data dengan sistem akademik pusat.
- Pengelolaan log aktivitas dan jejak audit.
- Penyimpanan dokumen sensitif pengguna.

Threat modeling tidak mencakup:

- Keamanan infrastruktur fisik.
- Manajemen server hosting pihak ketiga.
- Integritas data pada database pusat IPB.

2. Data Flow Overview



3. Threat Actor

Alur data utama IPB Academic Service Helper:

Threat actor	Motivasi	Contoh ancaman
Cybercriminals	Keuntungan finansial (ekstorsi, pencurian data).	Menyebarkan ransomware untuk mengenkripsi data mahasiswa/staf dan menuntut pembayaran tebusan.
Script Kiddies	Iseng, tantangan, atau sekadar ingin mencoba alat peretasan.	Menggunakan tools otomatis yang tersedia publik untuk mencoba membobol akun atau melakukan serangan DDoS pada aplikasi web.
Mahasiswa Berbahaya	Mendapatkan keuntungan akademis ilegal atau iseng (sabotage).	Mencoba melakukan privilege escalation untuk mengakses modul staf atau memanipulasi data tiket miliknya sendiri agar disetujui tanpa syarat.
Staf Terkompromi	Kredensial staf dicuri (phishing) atau staf menyalahgunakan akses sah karena tekanan atau kelalaian.	Menggunakan akses staf untuk menyetujui dokumen palsu, membocorkan data pribadi mahasiswa, atau mengekspos database sensitif.

4. STRIDE Threat Analysis

Spoofing

Spoofing terjadi ketika penyerang berpura-pura menjadi pengguna lain.

Ancaman	Dampak	Mitigasi
Brute-force kata sandi akun.	Akun diambil alih.	Pembatasan login (rate limit).
Intersepsi sesi komunikasi aktif (Session Hijacking).	Sesi pengguna dicuri.	Protokol HTTPS/TLS.
Identitas palsu di database.	Pencatatan data fiktif.	Digital Signature (SHA-256/RSA).

Tampering

Tampering terjadi ketika data diubah tanpa izin.

Ancaman	Dampak	Mitigasi
Manipulasi NIM/IPK.	Data akademik tidak sah.	Enkripsi AES (data at rest).
Pengubahan isi tiket/dokumen (unauthorized)	Pengelolaan surat/tiket palsu.	Verifikasi Digital Signature.

Repudiation

Repudiation terjadi ketika pengguna menyangkal aktivitas yang pernah dilakukan.

Ancaman	Dampak	Mitigasi
Staf menyangkal persetujuan.	Hilang akuntabilitas staf.	Asas Non-Repudiation Digital Signature.
Mahasiswa menyangkal isi tiket.	Sulit menjatuhkan sanksi.	Pengikatan kriptografis tiket.
Pengguna menyangkal serangan.	Bukti tidak valid untuk memberi sanksi.	Audit Logging (IP & timestamp).

Information Disclosure

Information disclosure terjadi ketika data sensitif bocor kepada pihak yang tidak berhak.

Ancaman	Dampak	Mitigasi
Kebocoran database cloud.	Data pribadi terbongkar.	Enkripsi AES kolom sensitif.
<i>Sniffing</i> jaringan Wi-Fi.	Kredensial/pesan diintip.	Jalur komunikasi HTTPS/TLS.
Admin dapat melihat kata sandi.	Penyalahgunaan hak internal.	Hashing bcrypt pada kata sandi.

Denial of Service

Denial of Service terjadi ketika layanan dibuat tidak tersedia.

Ancaman	Dampak	Mitigasi
DDoS/Flood request ke API.	Server melambat/tumbang.	Mekanisme Rate Limiting API.
Serangan koneksi Slowloris.	Database Neon.tech exhausted.	Optimasi connection pooling.
Unggah file dokumen raksasa.	Penyimpanan server penuh.	Validasi batas ukuran file.

Elevation of Privilege

Elevation of privilege terjadi ketika pengguna memperoleh hak akses lebih tinggi dari seharusnya.

Ancaman	Dampak	Mitigasi
Mahasiswa menembak API khusus milik Staf TU.	Mahasiswa ilegal bisa mengakses fungsi admin luar izin.	Sistem mengembalikan error response berupa 403 Forbidden.
Manipulasi token di browser.	Akses ke dashboard admin.	Verifikasi integritas JWT/Session.
Serangan IDOR (ganti ID URL).	Mengintip tiket mahasiswa lain.	Pengecekan kepemilikan (owner check).

5. Risk Matrix

ID	Risiko	Likelihood	Impact	Level	Mitigasi Prioritas yang Telah Diterapkan
R1	Pengambilalihan akun mahasiswa melalui pemalsuan identitas login.	Medium	High	High	Autentikasi ketat menggunakan mekanisme verifikasi login aman.
R2	Modifikasi ilegal pada isi tiket pengaduan di database.	Low	High	Medium	Penerapan Digital Signature gabungan SHA-256 dan RSA.
R3	Perubahan parameter ID berkas persyaratan secara tidak sah.	Medium	High	High	Verifikasi digital signature menggunakan public key saat diakses.
R4	Intersepsi dan manipulasi data di tengah jaringan komunikasi.	High	High	Critical	Pengiriman data aman wajib menggunakan protokol HTTPS/TLS.
R5	Staf menyangkal telah menyetujui pengajuan berkas mahasiswa.	Low	Medium	Low	Digital signature mengikat isi tiket pada identitas pengaju.
R6	Pengintipan data kredensial mentah dari database yang bocor.	Low	High	Medium	Hashing kata sandi menggunakan metode algoritma bcrypt.
R7	Kebocoran NIM dan isi pesan sensitif milik mahasiswa.	Medium	High	High	Enkripsi kolom sensitif database menggunakan algoritma AES.
R8	Serangan flooding request API tiket secara masif.	High	Medium	High	Kontrol laju akses melalui fitur rate limiting API.
R9	Koneksi cloud database Neon.tech habis akibat request berat.	Medium	High	High	Optimasi connection pooling dan penutupan koneksi tidak aktif.
R10	Kelumpuhan storage akibat unggahan dokumen berukuran raksasa.	Medium	Medium	Medium	Validasi ukuran maksimal file restriction di sisi backend.
R11	Akses ilegal mahasiswa ke API khusus Staf TU.	Medium	High	High	Sistem mengembalikan error response berupa 403 Forbidden.
R12	Manipulasi nilai role token untuk menaikkan hak akses.	Medium	High	High	Penerapan Role-Based Access Control ketat di sisi backend.